NIST CSF 2.0 Assessment: Holladay End at BOHICA Garden / Holladay End Alpacas

Nov 9, 2026 · @Bridget

A cybersecurity risk assessment of a sole-proprietor livestock farm, using the NIST Cybersecurity Framework 2.0.

Scope

The assessment covers the devices, accounts, network and records used to run a 40-acre livestock farm in rural Tennessee with one operator. Information came from an owner interview and a review of current practices. Account and institution names are generalized for public release. A personal Linux laptop is out of scope because it is not used for farm business.

Identify

The farm runs on four devices, more than a dozen online accounts and a home fiber connection, all managed by one person. The biggest exposures are an unsupported Windows desktop, a factory-default Wi-Fi password, and backups kept in the same building as the originals.

Asset inventory (ID.AM)

Asset	Type	Notes
MacBook Pro (2020, M1)	Primary computer	Supported, daily use
Dell desktop	Secondary computer	Windows 10, no longer receiving security updates; cannot upgrade to Windows 11
iPhone	Mobile	Email and accounts
Google Pixel	Mobile	Email and accounts
Fiber router	Network	Wi-Fi password is the factory default printed on the device

Asset	Type	Notes
Two external hard drives	Storage	Backups and some animal records
Email accounts (several)	Cloud account	Primary contact and account recovery
Website (hosted builder)	Cloud account	Owner plus one family member with access
Social media (3 platforms)	Cloud account	Public-facing
Bank accounts (2)	Financial	
Payment apps (4)	Financial	Peer-to-peer and point-of-sale
Animal records	Data	Split across email, paper and external drives
Credit cards (several)	Financial	Two are owned by a family member and used for farm expenses
Research audio datasets	Data	Beehive acoustic recordings for a machine-learning project; stored on the second external drive

Risks found

Risk	Why it matters	Severity
Unsupported OS on the Dell	Windows 10 support ended October 2025, so new vulnerabilities stay unpatched	High
Default Wi-Fi password	Printed on the device; anyone who sees the router has network access	Medium
A dozen financial accounts and cards	Large attack surface for fraud and account takeover	High
MFA on most accounts, not all	Any account without MFA can be taken with one stolen password	High
Records in three places	No single authoritative copy; easy to lose or miss	Medium

Risk	Why it matters	Severity
Backups stored on site	Fire, flood or theft would destroy originals and backups together	Medium
Third-party website access	A second person can change the public site	Low
Cards owned by another person	Fraud or a dispute on those cards must go through the owner; farm spending mixes with someone else's credit	Medium

Govern

The operator holds every security role, but spending authority sits with a family member who funds the farm. Any fix that costs money needs that person's approval, so low-cost and no-cost controls come first.

Role (GV.RR)	Held by
Owner and risk decision-maker	Operator
System administrator	Operator
Incident responder	Operator
Budget approval	Family member (financial backer)

Finding	Why it matters	Severity
Security spending needs outside approval	Paid fixes (a supported computer, a password manager subscription) can stall without a clear business case	Medium
One person holds every role	No backup if the operator is unavailable; no second check on decisions	Medium
No written security policy or procedures	Nothing records how accounts, backups or a lost device are handled, so recovery depends on memory	Medium

Protect

About 95% of credentials are stored in a password manager; the rest sit in a separate file that has not been reconciled.

Control	Current state	Finding	Severity
Password management (PR.AA)	About 95% of passwords in a password manager; the rest in a separate file	The remaining credentials are outside the manager and may be stale or less protected	Low
Multi-factor authentication (PR.AA)	MFA on banks, credit cards and major retailers; many other accounts use "Sign in with Google"; remaining accounts not yet audited	The Google account is a single point of failure: whoever controls it controls every account that signs in through it. Unaudited accounts may lack MFA	High
Computer disk encryption (PR.DS)	FileVault enabled on the Mac	None; meets the control	—
Mobile device lock (PR.AA)	Passcode and biometric lock on both phones	None; meets the control	—
External drive encryption (PR.DS)	Unknown	Drives holding animal and business records may be readable by anyone who takes them	Medium
Backups (PR.DS)	Files saved to one external drive; the monthly copy to a second drive stopped when the Windows PC was retired	Only one backup copy now, kept in the same building as the originals	High
Router administration (PR.PS)	Provider-managed gateway; the owner cannot log into its settings	The owner cannot review or harden network settings (firmware, admin password, connected devices); security depends on the provider	Medium

Control	Current state	Finding	Severity
Website access (PR.AA)	Family member appears to have a separate login	Shared logins would make changes untraceable; needs confirming	Low

Detect, Respond, Recover

Account sign-in alerts are on and backups have been proven in a real hard drive failure. The gap is response: steps after an incident live only in the operator's head.

Function	Current state	Finding	Severity
Detect (DE.CM)	Email and bank sign-in alerts enabled; no visibility into the provider-managed network	Account compromise would be noticed; a compromised home network might not	Low
Respond (RS.MA)	Operator would remote-wipe a lost phone; no written steps for what follows	Without a checklist, key steps (resetting the Google account, signing out other sessions, alerting banks, locking the SIM) can be missed under stress	Medium
Recover (RC.RP)	After a hard drive failure, the operator installed a new drive and restored the computer. The backup drive was accidentally erased during that work and was also restored	Recovery is proven in a real incident. The incident also shows why a second backup copy matters: one mistake erased the first. That second copy has since stopped (see Protect)	—

Action plan

Nine of the twelve fixes cost nothing, so they come first; three need budget approval and are listed with the case for each.

No cost, in priority order

#	Action	Addresses	Severity
1	Harden the Google account. Verified in place: 2-Step Verification, two passkeys, phone sign-in prompt, recovery phone, and recovery accounts that each have 2-Step Verification. Backup codes stored in the password manager. Connected apps reviewed. Status: complete (2026-11-09)	Single point of failure for sign-in	High
2	Remove the Windows 10 desktop from farm use; reinstall it with a supported Linux distribution as a lab machine	Unsupported operating system	High
3	Copy the research audio and other files off the second drive, then reformat it for macOS with encryption turned on, resume monthly copies, and keep one drive in a separate building	Single on-site backup; unencrypted drives	High
4	Audit every remaining account and turn on MFA wherever it is offered	Accounts without MFA	High
5	Close or unlink payment apps and accounts that are no longer needed	Large financial attack surface	High
6	Write a one-page incident checklist: lost phone, compromised email, suspicious bank charge	No written procedures; informal response	Medium
7	Ask the internet provider for router management access or an admin password change	Provider-managed gateway	Medium
8	Move the remaining passwords into the password manager and delete the separate file	Credentials outside the manager	Low

#	Action	Addresses	Severity
9	Confirm the family member's website access uses her own login	Shared access	Low

Needs budget approval

Action	Addresses	Case for spending
Owner-controlled router behind the provider's gateway	Provider-managed gateway	Gives the owner control of firmware, passwords and connected devices
Cloud backup subscription	On-site backups	Protects records from fire, flood or theft without moving drives
Hardware security key for the Google account	Single point of failure for sign-in	Strongest protection against phishing for the account that unlocks the rest

Change the Wi-Fi password

The default Wi-Fi password should be replaced, but every camera and device must then be reconnected. Schedule it for a day with time to do all of them at once.